

Management should plan for obsolescence, EOL, and decommissioning of systems to understand the resource requirements throughout any system's expected life cycle. Planning for obsolescence and EOL allows management to consider how it will protect the confidentiality, integrity, and availability of the information on a system. The architectural process should include planning for system decommission, including the migration from the old system and disposal of all critical components, services, and information when systems need to be replaced. If management does not plan for system obsolescence, EOL, and decommissioning, sensitive information may be retained on discarded components. Unnecessary and potentially unprotected system components may unknowingly remain connected to the network, using resources and providing a potential avenue for compromise, similar to what happens with shadow IT.

## IV.C IT Architecture Design

IT architecture design includes determining the appropriate deployment environments. Design environments may be managed in-house or by a third-party service provider, including a cloud service provider. Whether in-house or outsourced, management may use a combination of physical and virtual design environments and should consider the risks and benefits of both. For example, if management is considering moving some operations to the cloud, management should determine how the entity will benefit from virtualization or a cloud-based solution and the design implications, personnel responsibilities, and security provisions of that decision. Physical and virtual design environments may not differ substantially; the differences will be apparent in the design's implementation.

Designing the architecture of an entity's IT systems may include "the placement of the virtualization solution and the selection of virtualization software."<sup>42</sup> Entities may incorporate virtualization into their architecture design to reduce costs and risks of maintaining and managing multiple pieces of physical hardware. Virtualization allows virtual elements to be transferrable between different pieces of hardware within physical or third-party-hosted environments, including cloud environments. In designing the entity's virtual environment, management should consider the design risks associated with the following elements:

- **Virtual machines (VM).** To address the lack of visibility and control over the entity's virtual environment, management should design secure virtual infrastructures, including the ability to oversee the interconnectivity and segmentation of VMs.
- **Hypervisors.** To ensure visibility and control of the environment and address the susceptibility to unauthorized access, malware, and mismanaged traffic, management should design where the hypervisors sit and the connectivity between hypervisors and VMs.
- **Containers.** To manage container vulnerabilities, unintentional interactions (e.g., between containers and applications or containers and host OSs), and container failures (e.g., security misconfiguration, application programming interface [API] disconnection, and lack of portability), management should have vulnerability management processes, employ segmentation, and provide the ability to monitor containers. Additionally, to avoid having to re-create data when updating and replacing containers, management should design for storing data outside of the container.

---

<sup>42</sup> Refer to NIST SP 800-125, [Guide to Security for Full Virtualization Technologies](#).

- **Microservices.** To address the risks to application compatibility and functionality, management should have a design process that allows for the use of microservices as an integrated component of overall IT operations. Additionally, management should address the risks to security (e.g., having multiple microservices can increase the financial institution's attack surface), reliability (e.g., ability to re-use and API alignment with business processes), and latency (e.g., fault tolerance and scalability) in the entity's development process. For more information, refer to the *IT Handbook's* "[Development and Acquisition](#)" booklet.

Other considerations include the placement and selection of storage, design of network topology, availability of bandwidth, and need for management reporting systems. Management also should consider designing its systems to allow for the implementation of monitoring tools (e.g., identifying node and system failures in the cloud).

## IV.D Enterprise Architecture

EA is the description of an entity's entire set of information systems:

- How they are configured.
- How they are integrated.
- How they interface to the external environment at the enterprise's boundary.
- How they are operated to support the enterprise mission.
- How they contribute to the enterprise's overall security posture.

EA includes an entity's current state (also called baseline architecture), a future state (also called target architecture), and a plan to achieve the future state to meet the business objectives. EA provides a logical structure allowing management to classify, organize, and document elements of the entity's systems, functions, and information.

Smaller or less complex entities may not have EA, but those entities still should manage their existing architecture needs and planned changes. As an entity becomes larger or more complex and different systems are needed to support that growth, management should consider the implementation of EA to align its architecture with the entity's strategic plans and business functions. Regardless of entity size or complexity, management should evaluate the best approach to implement security and resilience and build these characteristics throughout its architecture. When legacy systems exist, management should analyze the functionality, including security and resilience, of current systems and identify gaps. This helps management determine whether the legacy system should be maintained, replaced, or retired and what effect that will have on EA.

Management may designate internal staff to design and manage EA, employ a third-party service provider, or use a combination of internal staff and third-party resources. For a larger or more complex entity, the chief architect's role typically includes EA responsibilities. The architect may help management analyze the current architecture using an industry framework to better align the architecture with the entity's strategic objectives. In a larger or more complex entity, a formal group (e.g., architecture review board) may assist in oversight of EA. Management may

use aspects of industry frameworks<sup>43</sup> as appropriate for the entity's business needs. A framework may have different characteristics (e.g., informal, formal, prescriptive, principles-based, or a hybrid).

---

<sup>43</sup> Some examples of industry architecture frameworks include The Open Group Architecture Framework (also known as TOGAF) and Federal Enterprise Architecture.

## V INFRASTRUCTURE

### Action Summary

Management should implement an IT infrastructure that achieves and promotes the objectives of confidentiality, integrity, and availability, and meets the entity's business objectives. Management should develop, document, and implement infrastructure control policies, standards, and procedures to safeguard facilities, technology, data, and personnel. IT infrastructure implementation practices should include redundancy and resilience for physical infrastructure elements and related products, services, and telecommunications.

Examiners should review for the following:

- Processes to identify, track, and monitor infrastructure components.
- Contractual arrangements addressing infrastructure, if applicable.
- Sufficient resources with infrastructure knowledge, skills, and expertise.
- Network configuration management and change control processes.
- Security and monitoring processes to analyze data traffic and detect anomalous activity.
- Software planning to address:
  - Scalability, interoperability, and portability.
  - Adequate software controls.
  - Use of and controls over open source software.
- Mainframe controls, if applicable, to address unique risks associated with mainframes.
- Security controls for the use of application programming interfaces (API).
- Environmental and physical access controls.

As previously stated, infrastructure refers to the physical elements, products, and services necessary to provide and maintain ongoing operations to support business activity and includes the maintenance of physical facilities. IT infrastructure includes hardware, network and telecommunications, software, IT environmental controls (e.g., power and HVAC), and physical access that allow for an enterprise IT environment's operation and management. IT infrastructure implementation should include considerations for server and data redundancy and resilience of telecommunications lines. Planning and designing an effective IT architecture facilitates management's ability to implement an IT infrastructure that achieves and promotes the objectives of confidentiality, integrity, and availability and supports the entity's business operations. IT infrastructure may be managed internally or externally by a third-party service provider, including a cloud service provider.

## V.A Hardware

NIST defines hardware as “the physical components of an information system.”<sup>44</sup> Hardware devices can be an ideal target for malicious actors. Therefore, management should track and monitor all hardware assets (whether or not they are connected to the network) to maintain an accurate and current record of the technology assets in its environment. This is often done with an accurate hardware inventory. Without an accurate inventory, management may encounter challenges in protecting hardware assets, managing cyber risks, and recovering from and responding to incidents. For more information, refer to the “[IT Asset Management](#)” section of this booklet.

Management should identify unauthorized technology assets and determine their disposition (e.g., remove, isolate (quarantine), or add them to the inventory). If an asset is determined to be unauthorized, management should evaluate how the device gained access and what, if any, compromise may have occurred. Management should determine whether the policy or procedures should be updated or whether additional training is necessary. Automated tools can assist management in maintaining the accuracy and availability of hardware components. Network discovery tools identify assets connected to the network and compare them to an inventory of authorized hardware assets. Advanced asset discovery tools (e.g., using dynamic host configuration protocol [DHCP] on servers or asset management tools using IP addresses) may be used to provide oversight of the entity’s technology asset inventory.

## V.B Network and Telecommunications

Networks are systems implemented with a collection of interconnected components. Such components may include routers, hubs, cabling, telecommunications controllers, key distribution centers, and technical control devices. Management should document and maintain a current inventory of network and telecommunications hardware and software and the network configuration. For more information, refer to the “[IT Asset Management](#)” section of this booklet.

NIST defines telecommunications as “the preparation, transmission, communication, or related processing of information (writing, images, sounds, or other data) by electrical, electromagnetic, electromechanical, electro-optical, or electronic means.” Given the critical nature of telecommunications, management should ensure appropriate redundancy capabilities in the entity’s telecommunications infrastructure and should understand the limitations of the entity’s third-party telecommunications providers’ infrastructure. Network and telecommunications infrastructure form the backbone for the entity’s data and voice communication, including information sharing and data transfer, and facilitate the integration of technology systems.

---

<sup>44</sup> Refer to the [NIST Glossary](#).

## V.B.1 Network

Network infrastructure consists of components (e.g., hardware and software) that transport data, support software functions, deliver services, and provide communications. Entity and customer traffic pass through these components, which include the following:

- Hubs and switches.
- Load balancers.
- Routers.
- Domain name system.
- Servers.
- Firewalls.
- IDS/IPS.
- SANs.

Once management has an accurate inventory that contains network components and information, management should document the network's baseline configuration, including processes to review and approve changes. Management should regularly assess and document compliance with the entity's baseline configuration<sup>45</sup> to validate that settings are in place and commensurate with the board's risk appetite. Intentional or unintentional misconfigurations can lead to system issues or exploitation of vulnerable services and settings by malicious actors. To reduce exposure to potential vulnerabilities and failures arising from unused services, management should implement appropriate network configuration management and change control processes. Configuration rules allowing traffic to pass through the network should be documented with the necessary detail to justify the business need. Management should periodically review the configurations of network devices. Tools are available to verify that network devices are using approved configurations and notify management when unauthorized changes are detected.

Network devices are often delivered with enabled services, open ports, and commonly known default passwords. Management should appropriately control networked devices by managing ports (e.g., close unnecessary ports), protocols (e.g., deactivate unsecure protocols), and services (e.g., disable unnecessary services) to minimize exposure to vulnerabilities or errors. For more information on these and other system "hardening" activities, refer to the *IT Handbook's* "[Information Security](#)" booklet. Ports, services, and protocols should be mapped to the technology asset inventory. Automated tools are available to perform port scans to validate that only approved ports, protocols, and services are in use. The latest version of security-related updates should be installed on network devices, when appropriate. For more information, refer to the "[Patch Management](#)" section of this booklet.

A server is a computer or device on a network that manages network resources. Examples include file servers (to store files), print servers (to manage one or more printers), network servers (to manage network traffic), and database servers (to process database queries). A server's standard, or baseline, image is the approved set of server configurations, applications,

---

<sup>45</sup> Guidance for implementing best practices for server configurations can be found at the [NIST National Checklist Program](#) and through other industry sources (e.g., [Center for Internet Security](#)).

and systems, which can be used to deploy servers consistently and rebuild them more easily and quickly, when necessary. Management should maintain standard images (or templates) of the entity's servers. Standard images of servers should be stored securely, and if a server needs to be rebuilt (e.g., upon discovery of an infected system), management should use clean, trusted images to restore the server. Deviations from the standard image should be documented, reviewed, and approved.

Management should implement security and monitoring throughout the entity's network to monitor system components, analyze incoming and outgoing data traffic, and alert authorized personnel if anomalous activity is detected. To accomplish this, security and monitoring mitigation strategies include the following:

- Use of software tools to protect against and monitor for malicious actors scanning for internet-accessible services or open ports.
- Implementation of firewalls and packet filtering to limit internet traffic to exclude services and ports (e.g., whitelist and blacklist).
- Deployment of IDS/IPS that use signature-based detection, anomaly-based detection, and stateful protocol analysis to detect and prevent attacks against the network or attacks against services, systems, applications, or data. IDS/IPS alert personnel to potential attacks, while IPS can be configured to take an action predefined by management, such as blocking various types of activities.
- Use of internal tools (e.g., data loss prevention, email content filtering, and internal IDS/IPS) to detect, identify, and prevent misuse by entity personnel.

When possible, management should perform administrative activities from dedicated workstations (used exclusively by administrators to manage the network's technology devices) located on an isolated portion of the network not used for regular business activity. Management should use multifactor authentication over encrypted network connections for administrators accessing and managing network devices.

## **V.B.2 Telecommunications**

Telecommunications infrastructure should be appropriate for current and anticipated internal traffic needs and have sufficient connectivity to facilitate external communications. Telecommunications infrastructure includes both voice and data transmissions that are broken up into multiple packets to facilitate transmission of those packets over shared paths. Telecommunications packets typically incorporate message content and completion validation messages. Between telecommunications endpoints, packets can be lost, encounter interference, or arrive out of order. Capacity, latency, and connectivity issues can affect the arrival of packets or completion of messages. Therefore, management should monitor telecommunications traffic. In addition, administrators should periodically review network devices to identify any that are operating in promiscuous mode or acting as packet "sniffers" for network traffic.



Management should physically secure telecommunications equipment<sup>46</sup> and restrict and monitor access (e.g., through access devices, logs, and cameras). Changes to telecommunications equipment and configurations should follow enterprise change control standards, including approval, testing, and migration to production. Identification, authorization, and authentication to access (including remote access) telecommunications systems should follow entity policies, standards, and procedures, including approval and documentation of exceptions. Documented wiring strategies (e.g., schematics and color coding) and organized cables facilitate easy troubleshooting, repair, and upgrade.

An entity's telecommunications infrastructure components should be designed and built for resilience. Loss of telecommunications can have a material impact on the ability of an entity to function, exposing it to legal, reputation, and financial risks. Management has little direct control over the telecommunications services beyond the entity's network. The telecommunications lines are subject to environmental risks (e.g., weather or natural disasters) and other risks (e.g., terrorism, sabotage, or accidents), which can damage communications cables and equipment at the entity, the telecommunications service provider, or in between. Where available, the entity's selection of infrastructure components and telecommunications providers should ensure access to a diversity of suppliers and connectivity to avoid a single point of failure. Management should implement route diversity, where available, to ensure data can travel along an alternate route if its primary path is blocked. For more information, refer to the *IT Handbook's* "[Business Continuity Management](#)" booklet.

The telecommunications services sector is designated as a critical infrastructure sector for national security and emergency preparedness. The telecommunications services sector provides support for the clearing, payment, and settlement processes, which are considered critical activities in another critical infrastructure sector, the financial services sector. For more information, refer to the *IT Handbook's* "[Business Continuity Management](#)" booklet.

### **V.B.2(a)      *Voice Communications***

Voice communications are critical to meeting business needs by facilitating understanding and interactions among personnel, internal and external entity customers, and third-party service providers. Regardless of the type of voice communication solution (e.g., voice over internet protocol [VoIP], dial-up, or mobile), risks include quality of service degradation (e.g., echo or dropouts), resilience (e.g., loss of voice communication), and security (e.g., eavesdropping), which can lead to reputation risks (e.g., failure to address time-sensitive issues) and loss of business. Therefore, management should address these risks through their development and acquisition processes and in their written policies, procedures and practices.

Entities often use VoIP for internal and external voice communications.<sup>47</sup> VoIP refers to the transmission of voice communications over the internet rather than through the public switched telephone network (PSTN). When a telephone call is made using VoIP, the caller's voice is

---

<sup>46</sup> Typically, telecommunications equipment is located in a separate telecommunications closet or room.

<sup>47</sup> For the purposes of this booklet, voice communications refers to the transmission of speech over communication (e.g., telephone) lines.



translated into a stream of data packets. The data packets are transmitted over the internet and converted to a voice signal on the other end of the communication. In addition to an IP-enabled telephone, VoIP systems include call managers, gateways, routers, firewalls, and protocols. The call manager performs the functions of a traditional phone network and is the core of the VoIP system. A VoIP gateway provides conversion of calls between the data network and the PSTN. Routing and switching infrastructure provides the basic network connectivity and transport.

As with telecommunications in general, the risks associated with VoIP include service quality (e.g., packet delays resulting in garbled communication), failure of communication (e.g., loss of voice communication), and security issues. Security issues include configuration weaknesses in VoIP devices and underlying OSs that enable denial of service (DOS) attacks, eavesdropping, voice alteration (hijacking), and toll fraud (theft of service). VoIP is susceptible to the same risks as data networks that use the internet, such as exposure to viruses, worms, trojans, and man-in-the-middle attacks. Each of these can result in the loss of confidentiality, integrity, and availability.

Management should perform a comprehensive risk assessment to ensure the confidentiality, integrity, and availability of voice communications using VoIP technology. When considering VoIP in the design of its network architecture, management should implement physical and logical controls in the VoIP environment and evaluate options for backup systems (e.g., hard-wired communication lines) that will provide redundancy in communication during power outages.<sup>48</sup> Traditional security controls may not provide appropriate security for VoIP systems, therefore, management should consider control solutions specific to VoIP, such as VoIP-ready firewalls.

### **V.B.2(b)**      *Data Communications*

Data communications is the transfer of data over networks<sup>49</sup> using a combination of telecommunications services and network devices. Networks connect devices within a single geographic site or can connect multiple geographically dispersed entity and third-party service provider sites. They connect servers, end user devices (e.g., workstations, laptops, and mobile devices), wireless routers, and network security devices, such as firewalls and IDS/IPS.

Entities contract with telecommunications service providers for the physical connection supporting data communications among network sites. Given the network's importance to the entity's infrastructure, management should monitor incoming and internal data communications traffic for problems such as outages, connectivity degradation, throughput issues, capacity concerns, and other anomalies. Inadequate maintenance or an inadequate response to problems may lead to degraded data communications service levels. Management should implement redundant telecommunications services (e.g., alternate telecommunications providers or lines)

---

<sup>48</sup> Widely accepted practices are available in [NIST SP 800-58, \*Security Considerations for Voice Over IP Systems\*](#).

<sup>49</sup> Networks can be composed of local area networks, wide area networks (WAN), and metropolitan area networks (MAN). WANs or MANs extend a data network to geographically dispersed offices, operations centers, service providers, and partners.

where appropriate and establish work-around procedures for situations where redundant telecommunications are not feasible.

## V.C Software

NIST defines software as computer programs (which are stored in and executed by computer hardware) and associated data (which also are stored in the hardware) that may be dynamically written or modified during execution. As part of infrastructure planning, management should determine the types of software needed to implement the entity's strategic objectives. Software implementation planning is fundamental to the confidentiality, integrity, and availability of the entity's data that interact with software. Management should consider the software's scalability, interoperability, and portability. As with its other infrastructure elements, management should perform the following:

- Track and monitor the entity's software assets whether they rely on network connectivity or are strictly isolated to individual workstations.
- Maintain an accurate and current record of the software assets in its environment, often through the use of software inventories.
- Periodically review existing software to meet changes in the entity's strategic objectives and operational goals.

The following sections describe the various developed or acquired software types and associated risks with the use of each.

### V.C.1 Internally and Externally Developed Software

Understanding the types of software needed to meet the entity's infrastructure and operational requirements is key to successful software implementation. In addition to choosing software, management should consider whether it develops the software internally or obtains the software from a third party. Options include the following:

- **Internally developed software:** An entity's internal development team can develop software or management can engage third-party development teams to develop software on the entity's behalf. Management is responsible for maintaining the software; therefore, entity personnel should have the resources and expertise to stay abreast of vulnerabilities and develop software updates and patches to promote the security and resilience to meet business needs. Refer to the *IT Handbook's* "[Development and Acquisition](#)" booklet for more information on internally developed software.
- **Externally developed software:** Externally developed software is available in multiple forms. These include the following:
  - **Commercial off-the-shelf (COTS) software:** COTS is a software and/or hardware product that is commercially ready-made and available for sale, lease, or license to the general public. COTS is also referred to as off-the-shelf. COTS software is built with default functionality and configurations to accommodate a variety of uses. It offers